



HACKTHEBOX

Nubilum-2 Writeup



Prepared by: n4cho

Machine Author(s): n4cho

Difficulty: Easy

Scenario

Leading telecoms provider Forela uses AWS S3 as an essential part of their infrastructure. They can deploy applications quickly and do effective analytics on their sizable dataset thanks to it acting as both an application storage and a data lake storage.

Recently, a user reported an urgent issue to the helpdesk: an inability to access files within a designated S3 directory. This disruption has not only impeded critical operations but has also raised immediate security concerns.

The urgency of this situation demands a security-focused approach. Reports of a misconfigured S3 Bucket policy for the forela-filere share bucket, resulting in unintended public access, highlight a potential security vulnerability that calls for immediate corrective measures. Consequently, a thorough investigation is paramount.

In order to rectify this situation, you are tasked to diligently identify who initiated the actions, how these actions were executed, and what specifically transpired with the S3 objects, leading to their inaccessibility. This comprehensive understanding is essential for a targeted and effective resolution.

Initiating with a comprehensive analysis of the AWS CloudTrail logs will provide a detailed record of all interactions with the affected S3 bucket. This step is pivotal in comprehending the entire extent of the incident and ensuring the necessary actions are taken to address it from a security perspective.

Artifacts Provided

- CloudTrail Logs

Skills Learnt

- CloudTrail Analysis
- AWS Services Familiarity
- Threat Actor Identification
- Privilege Escalation Awareness
- Log Querying and Analysis using Splunk

Initial Analysis

By examining the provided CloudTrail logs, this will give us insight into the situation and uncover any anomalous activities or unauthorized accesses that may have led to the reported disruption.

First off, what is CloudTrail? CloudTrail is an Amazon service that logs all your AWS account's activities which includes events that happened in AWS management web console, Command Line Interfaces (CLI) and Application Programming Interface (API). It keeps track of everything that happens, so that organizations can monitor and investigate what's happening, trace changes, and create a full audit trail, which is essential for maintaining a secure, well-governed AWS environment while protecting sensitive data from potential intrusions.

Events are saved in CloudTrail log files in the JSON format, which may not be very user-friendly for direct examination. Let's take a look into one of the CloudTrail log downloaded.

```
(kali@kali)-[~/949622803460/CloudTrail/ap-southeast-1/02]
$ cat 949622803460_CloudTrail_ap-southeast-1_20231102T1325Z_dsampSpJ3okGAaGm.json
{"Records":[{"eventVersion":"1.08","userIdentity":{"type":"IAMUser","principalId":"AIDA52GPOBQCMZGBDCDL6
n:aws:iam::949622803460:user/forela-superuser","accountId":"949622803460","userName":"forela-superuser"}
":"2023-11-02T13:24:34Z","eventSource":"signin.amazonaws.com","eventName":"ConsoleLogin","awsRegion":"ap
1","sourceIPAddress":"52.77.60.127","userAgent":"Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/5
L, like Gecko) Chrome/118.0.0.0 Safari/537.36","requestParameters":null,"responseElements":{"ConsoleLogi
"},"additionalEventData":{"LoginTo":"https://s3.console.aws.amazon.com/s3/buckets/forela-fileshare?regio
&state=hashArgs%23&tab=permissions&isauthcode=true","MobileVersion":"No","MFAUsed":"No"},"eventID":"878b
3b9-87b7-5d7e5b183eab","readOnly":false,"eventType":"AwsConsoleSignIn","managementEvent":true,"recipient
"949622803460","eventCategory":"Management","tlsDetails":{"tlsVersion":"TLSv1.3","cipherSuite":"TLS_AES_
256","clientProvidedHostHeader":"ap-southeast-1.signin.aws.amazon.com"}}}]}
```

To enhance readability and analysis, we can utilize online tools or JSON processing utilities like jq to convert these strings into a more digestible format.

```
(kali@kali)-[~/.../949622803460/CloudTrail/ap-southeast-1/02]
$ cat 949622803460_CloudTrail_ap-southeast-1_20231102T1325Z_dsampSpJ3okGAaGm.json | jq .
{
  "Records": [
    {
      "eventVersion": "1.08",
      "userIdentity": {
        "type": "IAMUser",
        "principalId": "AIDA52GPOBQCMZGBDCDL6",
        "arn": "arn:aws:iam::949622803460:user/forela-superuser",
        "accountId": "949622803460",
        "userName": "forela-superuser"
      },
      "eventTime": "2023-11-02T13:24:34Z",
      "eventSource": "signin.amazonaws.com",
      "eventName": "ConsoleLogin",
      "awsRegion": "ap-southeast-1",
      "sourceIPAddress": "52.77.60.127",
      "userAgent": "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/118.0.0.0 Safari/537.36",
      "requestParameters": null,
      "responseElements": {
        "ConsoleLogin": "Success"
      },
      "additionalEventData": {
        "LoginTo": "https://s3.console.aws.amazon.com/s3/buckets/forela-fileshare?region=us-east-1&state=hashArgs%23&tab=permissions&isauthcode=true",
        "MobileVersion": "No",
        "MFAUsed": "No"
      },
      "eventId": "878b9818-e73d-43b9-87b7-5d7e5b183eab",
      "readOnly": false,
      "eventType": "AwsConsoleSignIn",
      "managementEvent": true,
      "recipientAccountId": "949622803460",
      "eventCategory": "Management",
      "tlsDetails": {
        "tlsVersion": "TLSv1.3",
        "cipherSuite": "TLS_AES_128_GCM_SHA256",
        "clientProvidedHostHeader": "ap-southeast-1.signin.aws.amazon.com"
      }
    }
  ]
}
```

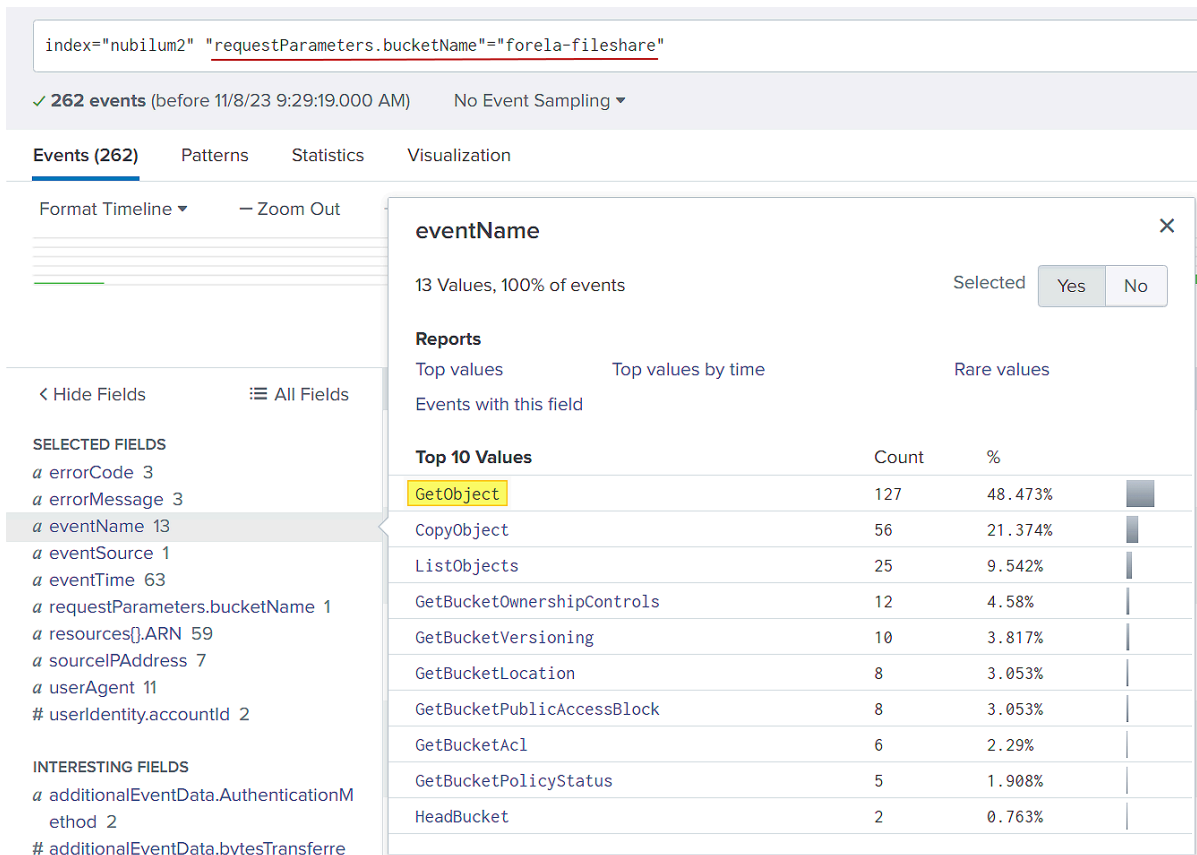
With this improved structure, we can readily identify crucial details such as recorded userName, eventTime, eventName, and more within the JSON log file.

Yet, when dealing with numerous JSON files (potentially in the hundreds or thousands), comprehensively analyzing them all at once can be a daunting task. This is precisely where robust log management, monitoring, and analysis platforms like the ELK Stack and Splunk prove invaluable.

Once we've efficiently ingested all the evidence and configured the display of key fields, we can proceed with our in-depth analysis!

There are several steps to initiate an investigation using AWS CloudTrail. Given that we have identified the affected S3 bucket, we can start by filtering the logs based on it. This way, we can narrow down our focus to events specifically related to that particular bucket. Additionally, considering that the bucket led to unintended public access, it's important to examine both the accessed objects ('GetObject') and the request information regarding the bucket ('ListObjects').

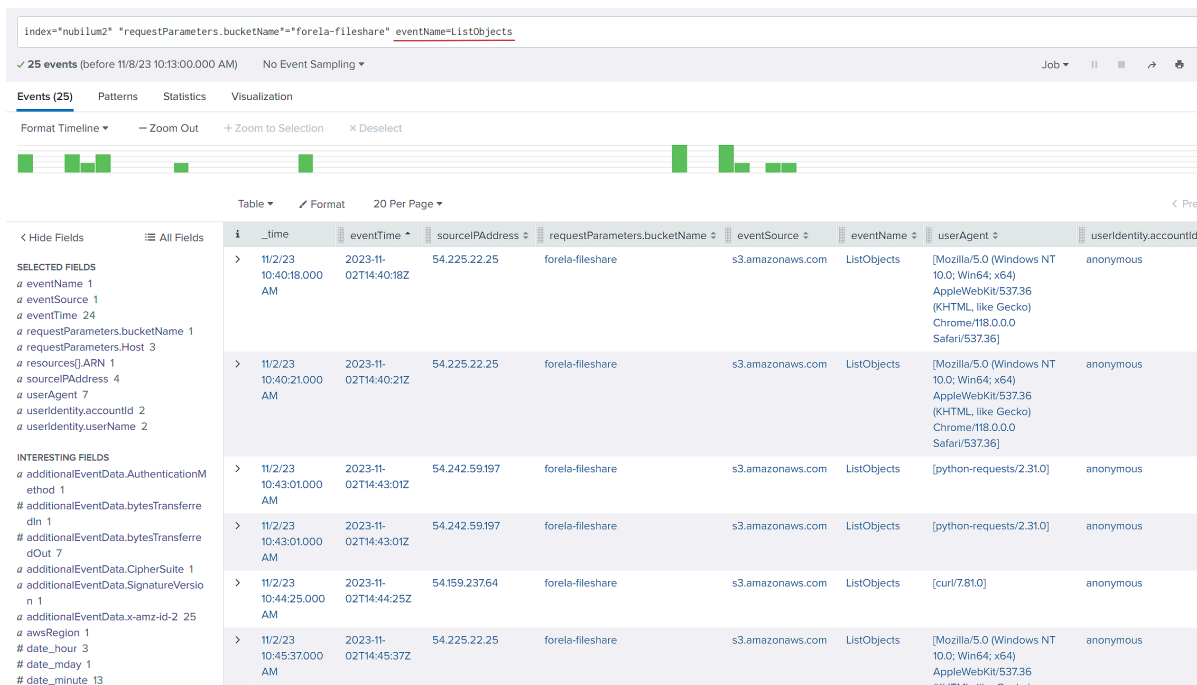
Selecting the eventName ListObject for a quick check confirms that the "forela-fileshare" bucket is publicly accessible. This is evident from the anonymous account ID displayed, suggesting that the request to list (or get) objects was made without valid AWS credentials.



Questions

1. What was the originating IP address the Threat Actor (TA) used to infiltrate the Forela's AWS account?

To pinpoint the infiltrator, we can utilize Splunk's filtering capabilities to scrutinize all source IP addresses that interacted with the affected S3 bucket. One particular IP address stands out, displaying a notably higher frequency of interactions compared to others. It's advisable to investigate the specific requests made by this address within the bucket.



By thoroughly reviewing the requested events, it becomes evident that there has been a notable occurrence unusual events and unauthorized use of multiple access keys. These keys were likely obtained from the compromised S3 bucket.

index="nubilum2" "requestParameters.bucketName"="forela-fileshare"

✓ 262 events (before 11/8/23 10:37:32.000 AM) No Event Sampling ▼

Events (262) Patterns Statistics Visualization

Format Timeline ▼ — Zoom Out + Zoom to Selection × Deselect

Table ▼ Format 20 Per Page ▼

< Hide Fields All Fields

SELECTED FIELDS

- a errorCode 3
- a errorMessage 3
- a eventName 13
- a eventSource 1
- a eventTime 63
- a requestParameters.bucketName 1
- a requestParameters.Host 3
- a requestParameters.key 58
- a resources[].ARN 59
- a sourceIPAddress 7
- a userAgent 11
- # userIdentity.accountId 2
- a userIdentity.userName 3

INTERESTING FIELDS

- a additionalEventData.AuthenticationMethod 2
- # additionalEventData.bytesTransferredIn 2
- # additionalEventData.bytesTransferredOut 2

sourceIPAddress

7 Values, 100% of events Selected Yes No

Reports

- Top values
- Top values by time
- Rare values

Events with this field

Values	Count	%
54.242.59.197	129	49.237%
AWS Internal	56	21.374%
35.153.199.23	37	14.122%
52.77.60.127	18	6.87%
resource-explorer-2.amazonaws.com	8	3.053%
54.159.237.64	7	2.672%
54.225.22.25	7	2.672%

index="nubilum2" sourceIPAddress="54.242.59.197" | top limit=20 eventName

✓ 223 events (before 11/8/23 12:20:04.000 PM) No Event Sampling ▼

Events Patterns **Statistics (20)** Visualization

20 Per Page ▼ Format Preview ▼

eventName	count
GetObject	67
CopyObject	56
GetCallerIdentity	14
ListUserPolicies	11
ListGroupsForUser	11
ListAttachedUserPolicies	11
ListUsers	6
ListObjects	6
GetPolicyVersion	4
GetPolicy	4
ListInstanceProfiles	3
ListAccountAliases	3
DescribeOrganization	3
DescribeInstances	3
CreateAccessKey	3
UpdateLoginProfile	1
PutUserPolicy	1
PutObject	1
GetAccountPasswordPolicy	1
DescribeVpcs	1

This strongly supports the conclusion that the identified suspicious IP address is indeed the infiltrator.

Answer: 54.242.59.197

2. What was the time, filename, and Account ID of the first recorded s3 object accessed by the TA?

Upon closer inspection of the events tied to the malicious IP address, it becomes apparent that several requests were executed, including the retrieval of files from the affected S3 bucket.

New Search	
index="nubilum2" sourceIPAddress="54.242.59.197" top limit=20 userIdentity.userName	
✓ 223 events (before 11/8/23 12:31:42.000 PM) No Event Sampling ▼	
Events Patterns Statistics (6) Visualization	
20 Per Page ▼ ✓ Format Preview ▼	
userIdentity.userName	count
dev-policy-specialist	128
prod-EC2-readonly	32
prod-S3-readonly	18
prod-VPC-readonly	15
prod-IAM-readonly	9
dev-access-auditor	6

Hence, we can identify the initial object that the threat actor either viewed or downloaded along, with other important details.

```
11/2/23      { [-]
10:52:03.000 AM  additionalEventData: { [+]
                  }
                  awsRegion: us-east-1
                  eventCategory: Data
                  eventID: 6394c764-88b2-4b8a-9166-3a7b2208f1cf
                  eventName: GetObject
                  eventSource: s3.amazonaws.com
                  eventTime: 2023-11-02T14:52:03Z
                  eventType: AwsApiCall
                  eventVersion: 1.09
                  managementEvent: false
                  readOnly: true
                  recipientAccountId: 949622803460
                  requestID: G3X38CFCQH64630V
                  requestParameters: { [+]
                  }
                  resources: [ [-]
                              { [-]
                                ARN: arn:aws:s3:::forela-fileshare/_restricted/Priv-Keys/prod-EC2-readonly_accessKeys.csv
                                type: AWS::S3::Object
                              }
                              { [-]
                                ARN: arn:aws:s3:::forela-fileshare
                                accountId: 949622803460
                                type: AWS::S3::Bucket
                              }
                            ]
                  responseElements: null
                  sharedEventID: 63dfd225-ab3a-457d-a908-3f579ee8aeef
                  sourceIPAddress: 54.242.59.197
                  tlsDetails: { [+]
                  }
                  userAgent: [curl/7.88.1]
                  userIdentity: { [-]
                                accountId: anonymous
                                principalId:
                                type: AWSAccount
                              }
                  }
}
```

Answer: 2023-11-02T14:52:03Z,prod-EC2-readonly_accessKeys.csv,anonymous

3. How many Access Keys were compromised, at a minimum?

Looking at the events that the TA requested initially, we are able to see files that are ansible playbooks and filenames that has suffixed "_accessKeys.csv" which is the default names of AWS Keys as well. There is a possibility that there are also access keys stored in the ansible playbook but we are unsure since there is no event data showing that there is hard coded creds inside those files.

Upon reviewing the events requested by the TA, we have observed that there are ansible playbook files and filenames with the suffix "_accessKeys.csv" which is commonly used for default AWS Key names. While it is possible that access keys are stored within the ansible playbook, we cannot confirm this as there is no event data indicating the presence of hard-coded credentials in those files.

After reviewing the requested events from the TA, we have noticed the presence of ansible playbook files and filenames with the suffix "_accessKeys.csv", which is commonly used for default AWS Key names. Although it is possible that access keys are stored within the ansible playbook, we cannot confirm this due to the lack of event data indicating the presence of hard-coded credentials in those files.

index="nubilum2" sourceIPAddress="54.242.59.197" requestParameters.key="*accessKeys.csv"

22 events (before 11/8/23 10:19:12.000 PM)No Event Sampling

Events (22)PatternsStatisticsVisualization

Format TimelineZoom Out

< Hide FieldsAll Fields

SELECTED FIELDS
eventName 2
eventTime 10
requestParameters.bucketName 1
requestParameters.Host 2
requestParameters.key 7
resources().ARN 8
sourceIPAddress 1
userAgent 2
userIdentity.accountId 2
userIdentity.userName 1
INTERESTING FIELDS
additionalEventData.AuthenticationMethod 1
additionalEventData.bytesTransferredIn 1
additionalEventData.bytesTransferredOut 2
additionalEventData.CipherSuite 1
additionalEventData.SignatureVersion 1

requestParameters.key

7 Values, 100% of eventsSelectedYesNo

Reports

Top valuesTop values by timeRare values

Events with this field

Values	Count	%
_restricted/Priv-Keys/prod-EC2-readonly_accessKeys.csv	4	18.182%
_restricted/Priv-Keys/prod-VPC-readonly_accessKeys.csv	4	18.182%
_restricted/Priv-Keys/prod-IAM-readonly_accessKeys.csv	3	13.636%
_restricted/Priv-Keys/prod-S3-readonly_accessKeys.csv	3	13.636%
projects/Vendor-IAM_Role_Enhancement/PendingTest/dev-alerting-analyst_accessKeys.csv	3	13.636%
projects/Vendor-IAM_Role_Enhancement/PendingTest/dev-policy-specialist_accessKeys.csv	3	13.636%
projects/Vendor-IAM_Role_Enhancement/PendingTest/dev-access-auditor_accessKeys.csv	2	9.091%

Next, we can refine our query by filtering for downloaded files with the suffix "accessKeys.csv".

Table ▾		Format	20 Per Page ▾							
i	time	eventTime	sourceIPAddress	requestParameters.bucketName	eventName	userAgent	userIdentity.accountId	userIdentity.userName	requestParameters.Host	requestParameters.key
>	11/2/23 10:52:03.000 AM	2023-11-02T14:52:03Z	54.242.59.197	forela-fleshare	GetObject	[curl/7.88.1]	anonymous		forela-fleshare.s3.amazonaws.com	..restricted/Priv-Keys/prod-EC2-readonly_accessKeys.csv
>	11/2/23 10:52:29.000 AM	2023-11-02T14:52:29Z	54.242.59.197	forela-fleshare	GetObject	[curl/7.88.1]	anonymous		forela-fleshare.s3.amazonaws.com	..restricted/Priv-Keys/prod-IAM-readonly_accessKeys.csv
>	11/2/23 10:52:56.000 AM	2023-11-02T14:52:56Z	54.242.59.197	forela-fleshare	GetObject	[curl/7.88.1]	anonymous		forela-fleshare.s3.amazonaws.com	..restricted/Priv-Keys/prod-EC2-readonly_accessKeys.csv
>	11/2/23 10:53:33.000 AM	2023-11-02T14:53:33Z	54.242.59.197	forela-fleshare	GetObject	[curl/7.88.1]	anonymous		forela-fleshare.s3.amazonaws.com	..restricted/Priv-Keys/prod-S3-readonly_accessKeys.csv
>	11/2/23 10:53:49.000 AM	2023-11-02T14:53:49Z	54.242.59.197	forela-fleshare	GetObject	[curl/7.88.1]	anonymous		forela-fleshare.s3.amazonaws.com	..restricted/Priv-Keys/prod-VPC-readonly_accessKeys.csv
>	11/2/23 10:54:11.000 AM	2023-11-02T14:54:11Z	54.242.59.197	forela-fleshare	GetObject	[curl/7.88.1]	anonymous		forela-fleshare.s3.amazonaws.com	..restricted/Priv-Keys/prod-VPC-readonly_accessKeys.csv
>	11/2/23 10:54:24.000 AM	2023-11-02T14:54:24Z	54.242.59.197	forela-fleshare	GetObject	[curl/7.88.1]	anonymous		forela-fleshare.s3.amazonaws.com	projects/Vendor-IAM_Role_Enhancement/PendingTest/dev-alerting-analyst_accessKeys.csv
>	11/2/23 10:54:42.000 AM	2023-11-02T14:54:42Z	54.242.59.197	forela-fleshare	GetObject	[curl/7.88.1]	anonymous		forela-fleshare.s3.amazonaws.com	projects/Vendor-IAM_Role_Enhancement/PendingTest/dev-policy-specialist_accessKeys.csv
>	11/2/23 10:55:12.000 AM	2023-11-02T14:55:12Z	54.242.59.197	forela-fleshare	GetObject	[Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0]	anonymous		forela-fleshare.s3.amazonaws.com	..restricted/Ansible-Playbooks/ansible-analytics_server_playbook.txt
>	11/2/23 10:55:57.000 AM	2023-11-02T14:55:57Z	54.242.59.197	forela-fleshare	GetObject	[Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0]	anonymous		forela-fleshare.s3.amazonaws.com	..restricted/Ansible-Playbooks/ansible-db_server_playbook.txt
>	11/2/23 10:56:10.000 AM	2023-11-02T14:56:10Z	54.242.59.197	forela-fleshare	GetObject	[Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0]	anonymous		forela-fleshare.s3.amazonaws.com	..restricted/Ansible-Playbooks/ansible-web_server_playbook.txt

Answer: 7

- The TA executed a command to filter EC2 instances. What were the name and value used for filtering?

This information can be obtained by querying the DescribeInstances events as requested by the TA and by examining the items in the filterSet, we can uncover the name and value used for filtering.

The describe-instances command can be utilized by Threat Actors to discover and gather information about running instances within an AWS environment. In this case, the filter indicates that the Threat Actor was interested in identifying and potentially targeting instances that were currently in a running state.


```

11/2/23      { [-]
11:05:58.000 AM    awsRegion: us-east-2
                  eventCategory: Management
                  eventID: 72a9427e-10e0-4db7-9b1f-653b768d0741
                  eventName: DescribeInstances
                  eventSource: ec2.amazonaws.com
                  eventTime: 2023-11-02T15:05:58Z
                  eventType: AwsApiCall
                  eventVersion: 1.08
                  managementEvent: true
                  readOnly: true
                  recipientAccountId: 949622803460
                  requestID: 160d7dab-e250-4bff-91c1-3b610104ccab
                  requestParameters: { [-]
                      filterSet: { [-]
                          items: [ [-]
                              { [-]
                                  name: instance-state-name
                                  valueSet: { [-]
                                      items: [ [-]
                                          { [-]
                                              value: running
                                          }
                                      ]
                                  }
                              }
                          ]
                      }
                  }
                  instancesSet: { [-]
                  }
              }
          responseElements: null
          sourceIPAddress: 54.242.59.197
          tlsDetails: { [-]
              cipherSuite: ECDHE-RSA-AES128-GCM-SHA256
              clientProvidedHostHeader: ec2.us-east-2.amazonaws.com
              tlsVersion: TLSv1.2
          }
          userAgent: aws-cli/2.12.0 Python/3.11.4 Linux/6.3.0-kali1-cloud-amd64 source/x86_64.kali.2023 prompt/off command/ec2.describe-instances
          userIdentity: { [-]
              accessKeyId: AKIA52GPOBQCLJPSAI53
              accountId: 949622803460
              arn: arn:aws:iam::949622803460:user/prod-EC2-readonly
              principalId: AIDA52GPOBQC07KTCF6XL
              type: IAMUser
              userName: prod-EC2-readonly
          }
      }
  }
}

```

Answer: instance-state-name:running

5. Can you provide the count of unsuccessful discovery and privilege escalation attempts made by the TA before gaining elevated access with the compromised keys?

To efficiently identify failed discovery and privilege escalation attempts made by the TA, we can enhance our query by adding a filter of `errorCode="AccessDenied"`. By implementing this filter, we can streamline the process of detecting and analyzing unauthorized access attempts.

index="nubilum2" sourceIPAddress="54.242.59.197" errorCode="AccessDenied"						
✓ 42 events (before 11/9/23 2:19:52.000 AM) No Event Sampling ▼						
Events (42) Patterns Statistics Visualization						
Format Timeline ▼ — Zoom Out + Zoom to Selection × Deselect						
> Show Fields Table ▼ Format 20 Per Page ▼						
i	_time	eventTime	sourceIPAddress	requestParameters.bucketName	eventName	userAgent
>	11/2/23 10:43:05.000 AM	2023-11- 02T14:43:05Z	54.242.59.197	forela-storage	ListObjects	[python-
>	11/2/23 11:02:57.000 AM	2023-11- 02T15:02:57Z	54.242.59.197		DescribeOrganization	Boto3/1.1 Linux/4.1 99.102.a env/AWS Botocore Botocore
>	11/2/23 11:02:57.000 AM	2023-11- 02T15:02:57Z	54.242.59.197		ListAccountAliases	Boto3/1.1 Linux/4.1 99.102.a env/AWS Botocore Botocore
>	11/2/23 11:07:55.000 AM	2023-11- 02T15:07:55Z	54.242.59.197		ListAttachedUserPolicies	Boto3/1.1 Linux/4.1 99.102.a

Answer: 42

6. Which IAM user successfully gained elevated privileges in this incident?

Scanning the events further, we noticed that when the TA utilized the dev-policy-specialist IAM user account, it did not encounter any error codes while attempting to List events that had failed using the previous IAM accounts. This implies that the requests made by the TA were successful.

Furthermore, it was able to execute the PutUserPolicy action. https://docs.aws.amazon.com/IAM/latest/APIReference/API_PutUserPolicy.html

This can pose a risk as it allows a threat actor to escalate their privileges and obtain administrative-level access when compromising an account. By attaching a policy to the dev-policy-specialist IAM user account, the threat actor can grant themselves additional permissions that they were not originally authorized.

```

11/2/23      { [-]
11:21:32.000 AM
    awsRegion: us-east-1
    eventCategory: Management
    eventID: eed211e3-9c53-4157-86cc-8e5f7e10d7fb
    eventName: PutUserPolicy
    eventSource: iam.amazonaws.com
    eventTime: 2023-11-02T15:21:32Z
    eventType: AwsApiCall
    eventVersion: 1.08
    managementEvent: true
    readOnly: false
    recipientAccountId: 949622803460
    requestID: b9f84080-e9a7-4d91-a8b2-8b79c3a8d241
    requestParameters: { [-]
        policyDocument: {"Version": "2012-10-17", "Statement": [{"Effect": "Allow", "Action": "*", "Resource": "*"}]}
        policyName: sbhyy79zky
        userName: dev-policy-specialist
    }
    responseElements: null
    sourceIPAddress: 54.242.59.197
    tlsDetails: { [+]
    }
    userAgent: Boto3/1.10.2 Python/3.8.0 Linux/4.14.138-99.102.amzn2.x86_64 exec-env/AWS_Lambda_python3.8 Botocore/1.13.2 Botocore/1.13.1.49
    userIdentity: { [-]
        accessKeyId: AKIA52GPOBQCMBGZADBx
        accountId: 949622803460
        arn: arn:aws:iam::949622803460:user/dev-policy-specialist
        principalId: AIDA52GPOBQCG3LZF5EYW
        type: IAMUser
        userName: dev-policy-specialist
    }
}

```

Answer: dev-policy-specialist

7. Which event name permitted the threat actor to generate an admin-level policy?

Answer: PutUserPolicy

8. What is the name and statement of the policy that was created that gave a standard user account elevated privileges?

Answer: Sbhyy79zky, [{"Effect": "Allow", "Action": "*", "Resource": "*"}]

9. What was the ARN (Amazon Resource Name) used to encrypt the files?

Upon closer inspection of the events, it becomes apparent that there are instances where TA requested a large number of GetObject operations, indicating that it may have downloaded all of the files in the affected S3 bucket.

```

11:26:02.000 AM    additionalEventData: { [+]  

    }  

    awsRegion: us-east-1  

    eventCategory: Data  

    eventID: 86ad87f8-e53f-40ed-a4f9-405147f76c8e  

    eventName: CopyObject  

    eventSource: s3.amazonaws.com  

    eventTime: 2023-11-02T15:26:02Z  

    eventType: AwsApiCall  

    eventVersion: 1.09  

    managementEvent: false  

    readOnly: false  

    recipientAccountId: 949622803460  

    requestID: B7TN3GDBFV3093MMW  

    requestParameters: { [-]  

      Host: forela-fileshare.s3.us-east-1.amazonaws.com  

      bucketName: forela-fileshare  

      key: reports/Telecom_Strategy_Presentation_Q1_2023.pptx  

      x-amz-copy-source: forela-fileshare/reports/Telecom_Strategy_Presentation_Q1_2023.pptx  

      x-amz-server-side-encryption: aws:kms  

      x-amz-server-side-encryption-aws-kms-key-id: arn:aws:kms:us-east-1:263954014653:key/mrk-85e24f85d964469cba9e4589335dd0f4  

    }  

    resources: [ [-]  

      { [+]  

      }  

      { [+]  

      }  

    ]  

    responseElements: { [+]  

    }  

    sourceIPAddress: 54.242.59.197  

    tlsDetails: { [+]  

    }  

    userAgent: [aws-cli/2.12.0 Python/3.11.4 Linux/6.3.0-kali1-cloud-amd64 source/x86_64.kali.2023 prompt/off command/s3.cp]  

    userIdentity: { [-]  

      accessKeyId: AKIA52GP0BQCMBGZADB  

      accountId: 949622803460  

      arn: arn:aws:iam::949622803460:user/dev-policy-specialist  

      principalId: AIDA52GP0BQCG3LZF5EYW  

      type: IAMUser  

      userName: dev-policy-specialist  

    }  

  }  

}

```

Following the GetObject events, we can see that there are also CopyObject events.

eventTime	sourceIPAddress	requestParameters.bucketName	eventName	userAgent	userIdentity.accountId	userIdentity.userName	requestParameters.Host	requestParameters.key
2023-11-02T15:25:40Z	54.242.59.197	forela-fileshare	GetObject	[aws-cli/2.12.0 Python/3.11.4 Linux/6.3.0-kali1-cloud-amd64 source/x86_64.kali.2023 prompt/off command/s3.cp]	949622803460	dev-policy-specialist	forela-fileshare.s3.us-east-1.amazonaws.com	logs/access-logs9.csv
2023-11-02T15:25:40Z	54.242.59.197	forela-fileshare	GetObject	[aws-cli/2.12.0 Python/3.11.4 Linux/6.3.0-kali1-cloud-amd64 source/x86_64.kali.2023 prompt/off command/s3.cp]	949622803460	dev-policy-specialist	forela-fileshare.s3.us-east-1.amazonaws.com	reports/Q2_2023_Sales_Report.pdf
2023-11-02T15:25:40Z	54.242.59.197	forela-fileshare	GetObject	[aws-cli/2.12.0 Python/3.11.4 Linux/6.3.0-kali1-cloud-amd64 source/x86_64.kali.2023 prompt/off command/s3.cp]	949622803460	dev-policy-specialist	forela-fileshare.s3.us-east-1.amazonaws.com	customer_data/customer-data6.csv
2023-11-02T15:26:00Z	54.242.59.197	forela-fileshare	ListObjects	[aws-cli/2.12.0 Python/3.11.4 Linux/6.3.0-kali1-cloud-amd64 source/x86_64.kali.2023 prompt/off command/s3.cp]	949622803460	dev-policy-specialist	forela-fileshare.s3.us-east-1.amazonaws.com	
2023-11-02T15:26:01Z	54.242.59.197	forela-fileshare	CopyObject	[aws-cli/2.12.0 Python/3.11.4 Linux/6.3.0-kali1-cloud-amd64 source/x86_64.kali.2023 prompt/off command/s3.cp]	949622803460	dev-policy-specialist	forela-fileshare.s3.us-east-1.amazonaws.com	customer_data/customer-data4.csv
2023-11-02T15:26:01Z	54.242.59.197	forela-fileshare	CopyObject	[aws-cli/2.12.0 Python/3.11.4 Linux/6.3.0-kali1-cloud-amd64 source/x86_64.kali.2023 prompt/off command/s3.cp]	949622803460	dev-policy-specialist	forela-fileshare.s3.us-east-1.amazonaws.com	_restricted/Ansible-Playbooks/ansible_server_playbook.txt
2023-11-02T15:26:01Z	54.242.59.197	forela-fileshare	CopyObject	[aws-cli/2.12.0 Python/3.11.4 Linux/6.3.0-kali1-cloud-amd64 source/x86_64.kali.2023 prompt/off command/s3.cp]	949622803460	dev-policy-specialist	forela-fileshare.s3.us-east-1.amazonaws.com	_restricted/Ansible-Playbooks/ansible_analytics_server_playbook.txt

In essence, GetObject is an activity that allows you to obtain (view or download) an item from the S3 bucket. CopyObject, on the other hand, is an action that allows you to duplicate an object. This replica can be created inside the same bucket or between buckets. It produces a new object with the same content instead of directly accessing the object's content.

Scrutinizing one of the CopyObject events, we observe a request parameter containing a KMS key associated with an AWS account ID not owned by Forela. This implies that the object was encrypted using a key that is not managed or controlled by the organization. This introduces a potential security risk, as Forela will have limited control over the object, potentially leading to a serious security breach. The compromise of a major security control means that the owner of the key might be able to decrypt and access sensitive data, resulting in unauthorized exposure of critical information.

```
11:26:02.000 AM    additionalEventData: { [+]  
    }  
    awsRegion: us-east-1  
    eventCategory: Data  
    eventID: 86ad87f8-e53f-40ed-a4f9-405147f76c8e  
    eventName: CopyObject  
    eventSource: s3.amazonaws.com  
    eventTime: 2023-11-02T15:26:02Z  
    eventType: AwsApiCall  
    eventVersion: 1.09  
    managementEvent: false  
    readOnly: false  
    recipientAccountId: 949622803460  
    requestID: B7TN3GDBFV3093MW  
    requestParameters: { [-]  
      Host: forela-fileshare.s3.us-east-1.amazonaws.com  
      bucketName: forela-fileshare  
      key: reports/Telecom_Strategy_Presentation_Q1_2023.pptx  
      x-amz-copy-source: forela-fileshare/reports/Telecom_Strategy_Presentation_Q1_2023.pptx  
      x-amz-server-side-encryption: aws:kms  
      x-amz-server-side-encryption-aws-kms-key-id: arn:aws:kms:us-east-1:263954014653:key/mrk-85e24f85d964469cba9e4589335dd0f4  
    }  
    resources: [ [-]  
      { [+]  
      }  
      { [+]  
      }  
    ]  
    responseElements: { [+]  
    }  
    sourceIPAddress: 54.242.59.197  
    tlsDetails: { [+]  
    }  
    userAgent: [aws-cli/2.12.0 Python/3.11.4 Linux/6.3.0-kali1-cloud-amd64 source/x86_64.kali.2023 prompt/off command/s3.cp]  
    userIdentity: { [-]  
      accessKeyId: AKIA52GP0BQCMBGZADBX  
      accountId: 949622803460  
      arn: arn:aws:iam::949622803460:user/dev-policy-specialist  
      principalId: AIDA52GP0BQCG3LZF5EYW  
      type: IAMUser  
      userName: dev-policy-specialist  
    }  
  }
```

Answer: arn:aws:kms:us-east-1:263954014653:key/mrk-85e24f85d964469cba9e4589335dd0f4

10. What was the name of the file that the TA uploaded to the S3 bucket?

To promptly spot uploaded objects in an S3 bucket, we can use the filter eventName=PutObject. Judging by the filename, it appears that the TA left a ransomware note intended for Forela employees. Ransomware occurrences in AWS setups are not infrequent and warrant serious attention from organizations. Even with AWS's robust security measures in place, policy misconfigurations, weak credentials, and vulnerabilities remain potential entry points for threat actors, opening the door to possible ransomware deployment.

```

11/2/23      { [-]
11:26:22.000 AM
  additionalEventData: { [+]
  }
  awsRegion: us-east-1
  eventCategory: Data
  eventID: 6993a945-9b52-450f-a135-b9b6673a060f
  eventName: PutObject
  eventSource: s3.amazonaws.com
  eventTime: 2023-11-02T15:26:22Z
  eventType: AwsApiCall
  eventVersion: 1.09
  managementEvent: false
  readOnly: false
  recipientAccountID: 949622803460
  requestID: MMRZAWSBZHNGBDVY
  requestParameters: { [-]
    Host: forela-fileshare.s3.us-east-1.amazonaws.com
    bucketName: forela-fileshare
    key: README2DECRYPT.txt
  }
  resources: [ [+]
  ]
  responseElements: { [+]
  }
  sourceIPAddress: 54.242.59.197
  tlsDetails: { [+]
  }
  userAgent: [aws-cli/2.12.0 Python/3.11.4 Linux/6.3.0-kali1-cloud-amd64 source/x86_64.kali.2023 prompt/off command/s3.cp]
  userIdentity: { [+]
  }
}

```

Answer: README2DECRYPT.txt

11. Which IAM user account did the TA modify in order to gain additional persistent access?

It appears the Threat Actor isn't done yet. Continuing with the remaining events left by the TA, another significant discovery was made. This involved a request for a ListUsers action, followed by a CreateAccessKey event indicating an attempt at persistence. The TA successfully manipulated the forela-admin account by generating an additional access key, potentially as a backup in case the Forela Security Team manages to revoke access for the dev-policy-specialist account that was compromised.

```

11/2/23      { [-]
11:26:53.000 AM
  awsRegion: us-east-1
  eventCategory: Management
  eventID: d60b6d82-c29a-4672-a23b-12de46159065
  eventName: CreateAccessKey
  eventSource: iam.amazonaws.com
  eventTime: 2023-11-02T15:26:53Z
  eventType: AwsApiCall
  eventVersion: 1.08
  managementEvent: true
  readOnly: false
  recipientAccountID: 949622803460
  requestID: 7a469839-9fc5-43f5-bc2b-6aa159dc1b2f
  requestParameters: { [-]
    userName: forela-admin
  }
  responseElements: { [-]
    accessKey: { [-]
      accessKeyId: AKIA52GPOBQCAB3EEAXZ
      createDate: Nov 2, 2023 3:26:53 PM
      status: Active
      userName: forela-admin
    }
  }
  sourceIPAddress: 54.242.59.197
  tlsDetails: { [-]
    cipherSuite: ECDHE-RSA-AES128-GCM-SHA256
    clientProvidedHostHeader: iam.amazonaws.com
    tlsVersion: TLSv1.2
  }
  userAgent: aws-cli/2.12.0 Python/3.11.4 Linux/6.3.0-kali1-cloud-amd64 source/x86_64.kali.2023 prompt/off command/iam.create-access-key
  userIdentity: { [-]
    accessKeyId: AKIA52GPOBQCMBGZADBx
    accountID: 949622803460
    arn: arn:aws:iam::949622803460:user/dev-policy-specialist
    principalId: AIDA52GPOBQCG3LZF5EYW
    type: IAMUser
    userName: dev-policy-specialist
  }
}

```

Answer: forela-admin

12. What action was the user not authorized to perform to view or download the file in the S3 bucket?

Finally, let's turn our attention to the files that were tried to be opened. By employing the query "eventName=GetObject errorCode=AccessDenied" we can isolate events where accesses was attempted but failed.

Analyzing the event, it is evident that user John made an unsuccessful attempt to access Executive_Summary_Q1_2023.docx within the reports directory due to insufficient permissions for

kms:decrypt.

```
11/2/23      { [-]
12:03:24.000 PM  additionalEventData: { [+]
```

```
    }
    awsRegion: us-east-1
    errorCode: AccessDenied
    errorMessage: User: arn:aws:iam::949622803460:user/forela-john is not authorized to perform: kms:Decrypt on the resource associated with this ciphertext because the resource does not exist in this Region
    resource-based policies allow access, or a resource-based policy explicitly denies access
    eventCategory: Data
    eventID: 8c9f7d4b-e71c-468f-aba4-5d71717de3bd
    eventName: GetObject
    eventSource: s3.amazonaws.com
    eventTime: 2023-11-02T16:03:24Z
    eventType: AwsApiCall
    eventVersion: 1.09
    managementEvent: false
    readOnly: true
    recipientAccountId: 949622803460
    requestId: X3H4H6W5G9TCEW2B
    requestParameters: { [-]
```

```
      Host: forela-fileshare.s3.us-east-1.amazonaws.com
      X-Amz-Algorithm: AWS4-HMAC-SHA256
      X-Amz-Date: 20231102T160324Z
      X-Amz-Expires: 300
      X-Amz-SignedHeaders: host
      bucketName: forela-fileshare
      key: reports/Executive_Summary_Q1_2023.docx
      response-content-disposition: attachment
    }
    resources: [ [-]
```

```
      { [-]
        ARN: arn:aws:s3:::forela-fileshare/reports/Executive_Summary_Q1_2023.docx
        type: AWS::S3::Object
      }
      { [-]
        ARN: arn:aws:s3:::forela-fileshare
        accountId: 949622803460
        type: AWS::S3::Bucket
      }
    ]
  }
```

Answer: kms:Decrypt

To sum up, the threat actor took advantage of the policy misconfiguration in the S3 bucket that made it relatively easy for them to gain access to and encrypt files. This discovery provides insight into their tactics, as it demonstrates the degree to which they leveraged the compromised Identity and Access Management (IAM) user accounts to increase their privileges in Forela's AWS environment.

This breach of security protocols resulted in the unauthorized encryption of essential files, resulting in a significant disruption of operations as users are no longer able to decrypt or access critical data.

Furthermore, the ransomware note uploaded serves as a clear indication of the malicious intent behind this attack. Their intentional actions further demonstrate the calculated nature behind this attack and confirm the classification as a ransomware incident.